

01 — Lựa chọn 3 API & Phân tích đặc tả

Sinh viên: 23127195 · HW06 — API Testing · SUT: EShop ([ttbhanh/eshop-sut](#))

1. Ràng buộc chọn API

Theo §5 của đề bài:

- Chọn đúng **3 API**, mỗi API hiện thực một tính năng thuộc **Pool A, Pool B, Pool C**.
- Pool D (Mobile) không dùng vì bài này nhắm vào backend API.
- **Không trùng** với thành viên khác trong nhóm.

Thành viên khác trong nhóm đã nhận: **FR-02, FR-03, FR-08, FR-10, FR-14, FR-15**

→ sáu FR này bị loại khỏi danh sách ứng viên.

Danh sách còn lại sau khi loại trừ:

Pool	Còn lại
A	FR-01 (đăng ký), FR-04 (hồ sơ cá nhân) , FR-05 (danh sách/tìm kiếm), FR-06 (chi tiết SP)
B	FR-07 (giỏ hàng), FR-09 (mã giảm giá) , FR-11 (lịch sử đơn)
C	FR-12, FR-13, FR-16 (import CSV) , FR-17, FR-18, FR-19

2. Bộ API đã chọn

	P o o l	FR	Endpoint	Tham số chính	Kỹ thuật phủ được
API-1	A	FR-04 — Quản lý hồ sơ cá nhân	GET /api/users/me PUT /api/users/me	name , phone , shipping_address (+ role là trường ngoài hợp đồng)	Domain partition (3 tham số), State transition (ghi/đọc, partial update, trường bất biến), Security SEC-01/02/05/06 , Schema
API-2	B	FR-09 — Áp dụng mã giảm giá	POST /api/apply-coupon POST /api/coupon-usage	code , total_amount , user_id	Bảng quyết định 5 điều kiện C1–C5 , BVA trên min_order_amount , oracle số học cho công thức, State transition (số lượt/người), Security SEC-02/05 , Schema
API-3	C	FR-16 — Import sản phẩm từ CSV	POST /api/admin/import-products	products[] × (name , price , description , imageUrl , category_id)	Domain partition (cấu trúc mảng + 5 trường/dòng), State transition: tính nguyên tử all-or-nothing , Access control FR-12 / SEC-02/03/05 , Schema

3. Vì sao chọn bộ này

Bốn tiêu chí được áp dụng cho từng pool, theo đúng yêu cầu về phạm vi phủ của đề:

1. **Đủ tham số để phủ domain partition.** Đề yêu cầu "domain partitions on **every** parameter". API chỉ có 0–1 tham số (ví dụ `GET /api/cart`, `GET /api/orders/my-orders`) không đủ chất liệu. Ba API đã chọn có lần lượt **3, 3 và 5** tham số — riêng API-3 còn nhân thêm chiều "số dòng trong mảng".
2. **Có vòng đời trạng thái riêng, không mượn của FR-10.** Đề yêu cầu phủ state transition, nhưng FR-10 (state machine đơn hàng) đã thuộc về thành viên khác. Ba API này có ba vòng đời **độc lập**:
 - API-1: vòng đời hồ sơ + phiên (ghi → đọc → ghi đè, bảo toàn trường khi cập nhật một phần).
 - API-2: vòng đời số lượt dùng mã theo từng người (0 → 1 → ... → max → hết lượt).
 - API-3: vòng đời **giao dịch** import (bắt đầu → ghi n dòng → commit hoặc → rollback toàn bộ).
3. **Chạm được nhiều mục SEC.** Bộ 3 API chạm **SEC-01, SEC-02, SEC-03, SEC-05, SEC-06** (5/7 mục).
 - SEC-04 (escape khi hiển thị) thuần tầng UI — chỉ kiểm được gián tiếp ở API-3 qua `imageUrl` với giao thức `javascript:`.
 - SEC-07 (OTP) thuộc FR-03 đã do thành viên khác nhận, nên nằm ngoài phạm vi.
4. **Response có oracle kiểm chứng được.** API-2 mạnh nhất ở điểm này: FR-09 cho công thức tính tiền tương minh (percent và fixed) nên mỗi test case có một con số kỳ vọng chính xác, không phải chỉ kiểm "status 200".

4. Khoảng trống của đặc tả (phát hiện khi phân tích)

Đây là phần ảnh hưởng trực tiếp tới chất lượng prompt ở bước Generate:

1. `api_specification.md` **KHÔNG** chứa **SEC-01...SEC-07**. Các yêu cầu bảo mật nằm ở `README.md` (bản SRS) của SUT. Nếu chỉ đưa `api_specification.md` cho AI như đề bài mô tả ("Provide the SUT's API specification to an AI tool"), AI **không thể** sinh test case bảo mật đúng ngữ cảnh. Prompt của bước Generate vì vậy nạp **cả hai** tài liệu — xem `ai/prompts/`.
2. **Đặc tả API chỉ mô tả response 200.** Không có bảng mã lỗi. Toàn bộ kỳ vọng 4xx phải suy ra từ SRS + nguyên tắc REST, và điều này được ghi rõ trong trường `expected_by_spec` của từng test case.
3. **Ràng buộc nghiệp vụ nằm rải ở SRS, không ở đặc tả API:**
 - Định dạng số điện thoại (bắt đầu bằng 0, 10–11 chữ số) → chỉ có ở FR-04.
 - "Email không được phép thay đổi" → chỉ có ở FR-04, không có trong mục 2.2 của đặc tả API.
 - Điều kiện C3 dùng dấu `>=` → chỉ có ở bảng 5 điều kiện của FR-09.
 - Yêu cầu **rollback nguyên tử** khi import → chỉ có ở FR-16.
 - `price` phải là số **dương**, `name` tối đa **255** ký tự → chỉ có ở FR-15/FR-16.

Ba trong số các bug nghiêm trọng nhất tìm được (BUG-A2-03, BUG-A3-02, BUG-A1-01) nằm đúng vào những chỗ mà đặc tả API im lặng còn SRS thì nói rõ. Đây là lý do bước "human audit" không thể bỏ qua.

5. Xác nhận không trùng nhóm

Xem `docs/team-api-allocation.md` ở thư mục gốc repo.

⚠ **Việc sinh viên phải tự làm:** xác nhận lại lần cuối với hai thành viên còn lại (23127060, 23127259) rằng bộ **FR-04 / FR-09 / FR-16** không trùng, trước khi nộp bài.